

Penetration Testing Report

Web Application BNI



Jakarta Kota, 7 Agustus 2025

Document ID : WondrDesktop_0001

Persetujuan

	Name	Unit	Approval	Date
Created By	Muhammad Arya Revansyah	IT Security		07/08/2025
Checked By	Andrew	Project Manager		07/08/2025
Approved By	Muhammad Verly	Mentor		07/08/2025

Version Control

Version	Date	Author	Description
1.0	04/08/2025	Muhammad Arya Revansyah	First Report Released

Peringatan Dokumen

Kerahasiaan

Dokumen ini berisi informasi yang bersifat rahasia dan harus diperlakukan dengan hati-hati sebelum mendistribusikan salinan dokumen ini. Penggunaan yang tidak sah terhadap dokumen ini atau informasi yang terkandung di dalamnya dilarang. IT Security tidak bertanggung jawab atas tindakan tidak pantas atau kesalahan penggunaan dokumen ini oleh pihak lain atau kerusakan yang disebabkan oleh informasi yang terkandung dalam dokumen ini.

Penolakan Tanggung Jawab

Informasi yang disajikan dalam dokumen ini disediakan apa adanya. Penilaian kerentanan dan Pengujian Penetrasi merupakan analisis pada titik waktu tertentu, sehingga kemungkinan ada perubahan dalam lingkungan sejak pengujian yang tercantum dalam laporan ini dilakukan. Selain itu, kemungkinan kerentanan baru telah ditemukan sejak pengujian dilakukan. Oleh karena itu, laporan ini harus dianggap sebagai panduan, bukan representasi 100% dari risiko yang mengancam sistem, jaringan, dan website setelah pengujian dilakukan.

DAFTAR ISI

Persetujuan.....	2
Peringatan Dokumen.....	3
DAFTAR ISI.....	4
1. EXECUTIVE SUMMARY.....	5
1.1. INTRODUCTION.....	5
1.2. OBJECTIVE.....	5
1.3. TESTING TEAM.....	5
1.4. SCOPE OF TEST.....	5
1.5. SUMMARY OF SYSTEM SECURITY RISK.....	5
1.6. METHODOLOGY.....	5
2. RISK ANALYSIS.....	6
2.1. Severity Identification.....	6
2.2. OWASP Top 10 Web Application Security Risks 2021.....	6
3. DETAIL VULNERABILITIES.....	7
3.1. Web Application (https://wondrdesktop.my.id).....	7
3.1.1. Findings: Enumerasi pada Halaman Verifikasi KTP.....	7
3.1.2. Findings: Expose Version Control System Files.....	9
3.1.3. Findings: Expose version Information Response.....	10
3.1.4. Findings: Missing Content Security Policy (CSP) Header.....	12
3.1.5. Findings: Modern Web Application.....	14
3.1.6. Findings: Missing Anti-Clickjacking.....	15
3.1.7. Testing Vulnerability: SQL Injection.....	16
4. BUSINESS RISK.....	19
5. GENERAL RECOMMENDATIONS.....	19
6. CONCLUSION.....	20

1. EXECUTIVE SUMMARY

1.1. INTRODUCTION

Dokumen report ini menyajikan hasil pengujian penetrasi (penetration testing) yang dilakukan pada aplikasi web `wondrdesktop.my.id`. Pengujian ini bertujuan untuk mengidentifikasi dan menganalisis potensi kerentanan keamanan yang dapat dieksploitasi oleh pihak luar. Laporan ini merangkum temuan-temuan kunci, mengevaluasi tingkat risiko yang terkait dengan setiap kerentanan, dan memberikan rekomendasi strategis untuk meningkatkan keamanan *web application* secara keseluruhan. Ringkasan ini ditujukan bagi pihak manajemen dan *stakeholders* untuk memahami risiko keamanan yang ada dan mengambil keputusan yang tepat untuk mitigasi.

1.2. OBJECTIVE

Tujuan *report* ini adalah menguji *web application* untuk menemukan kerentanan keamanan yang membahayakan sistem. *Report* ini juga memberikan rekomendasi untuk membantu meningkatkan keamanan *web application*.

1.3. TESTING TEAM

Security Tester : Muhammad Arya Revansyah
Project Manager : Andrew

1.4. SCOPE OF TEST

Application:

<https://wondrdesktop.my.id>

Application Feature:

- Login
- Register
- OTP
- Dashboard

1.5. SUMMARY OF SYSTEM SECURITY RISK

Total *vulnerabilities* yang ditemukan pada sistem:

Critical	High	Medium	Low	Informational
1	1	2	1	1

1.6. METHODOLOGY

1. Planning & Preparation

Membuat perencanaan untuk proses testing.

2. Testing

Melakukan proses *testing* dengan berbagai attacks untuk menemukan kelemahan keamanan.

3. Reporting

Membuat *report* dari berbagai *vulnerabilities* yang ditemukan dan rekomendasi peningkatan keamanan.

2. RISK ANALYSIS

2.1. Severity Identification

CRITICAL	Masalah sangat serius yang dapat sepenuhnya mengancam sistem. Harus diperbaiki segera
HIGH	Risiko keamanan besar yang dapat berdampak serius pada situs web. Harus diperbaiki sesegera mungkin.
MEDIUM	Risiko moderat yang tidak terlalu mendesak tetapi tetap penting. Perbaiki setelah masalah kritis dan tinggi selesai.
LOW	Masalah minor yang biasanya tidak menimbulkan risiko langsung. Memperbaikinya kurang mendesak.
INFORMATIONAL	Bukan risiko langsung, tetapi berguna untuk diketahui. Biasanya tidak perlu diperbaiki kecuali jika digabungkan dengan masalah lain.

2.2. OWASP Top 10 Web Application Security Risks 2021

Number	Top 10 Web Application Risk
--------	-----------------------------

A1	Broken Access Control
A2	Cryptographic Failures
A3	Injection
A4	Insecure Design
A5	Security Misconfiguration
A6	Vulnerable and Outdated Components
A7	Identification and Authentication Failures
A8	Software and Data Integrity Failures
A9	Security Logging and Monitoring Failures
A10	Server-Side Request Forgery

3. DETAIL VULNERABILITIES

3.1. Web Application (<https://wondrdesktop.my.id>)

3.1.1. Findings: Enumerasi pada Halaman Verifikasi KTP

Risk Rating

Risk Severity: CRITICAL

Risk Score

Likelihood Risk Score	Impact Risk Score
7.125	7.75

Calculated:

<https://owasp-risk-rating.com/?v=39999996392166799>

Tools

- OWASP Zap
- Browser (Firefox)
- Browser (Chrome)

Description

Web application memiliki kerentanan enumerasi pada halaman verifikasi KTP. Ketika pengguna melakukan verifikasi yang tidak valid, sistem memberikan pesan kesalahan yang spesifik. Pesan tersebut akan menampilkan kolom

mana yang benar dan kolom mana yang salah dari data verifikasi KTP yang tersimpan.

Impact

- *Attacker* akan dapat mengidentifikasi NIK, Nama lengkap, dan tanggal lahir yang valid di sistem
- Informasi tersebut dapat digunakan untuk serangan *brute-force*

Recommendation

Terapkan pesan error login yang generik dan seragam sehingga *attacker* tidak akan mengetahui secara spesifik letak kesalahan.

Involved Team

- Front-End Developer
- UI/UX Designer
- Back-End Developer
- Project Manager

References

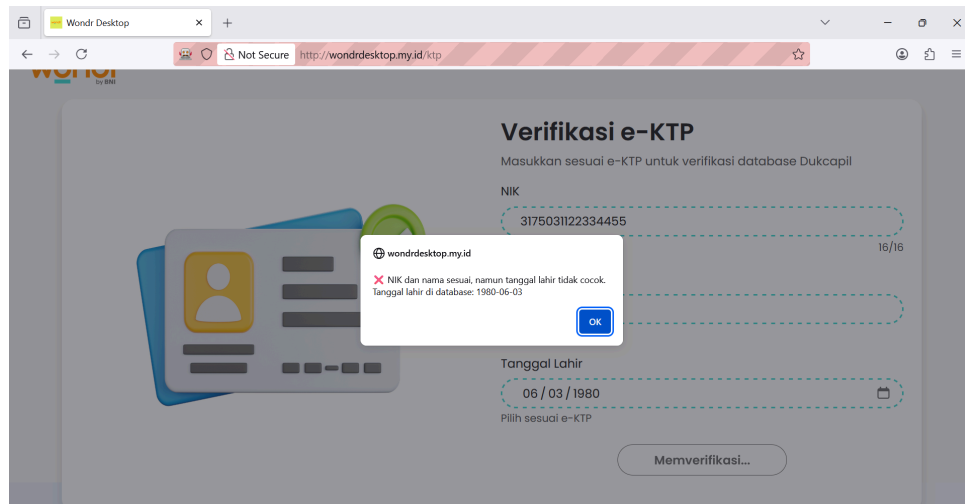
- https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/
- https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/03-Identity_Management_Testing/04-Testing_for_Account_Enumeration_and_Guessable_User_Account

OWASP Top 10 Category

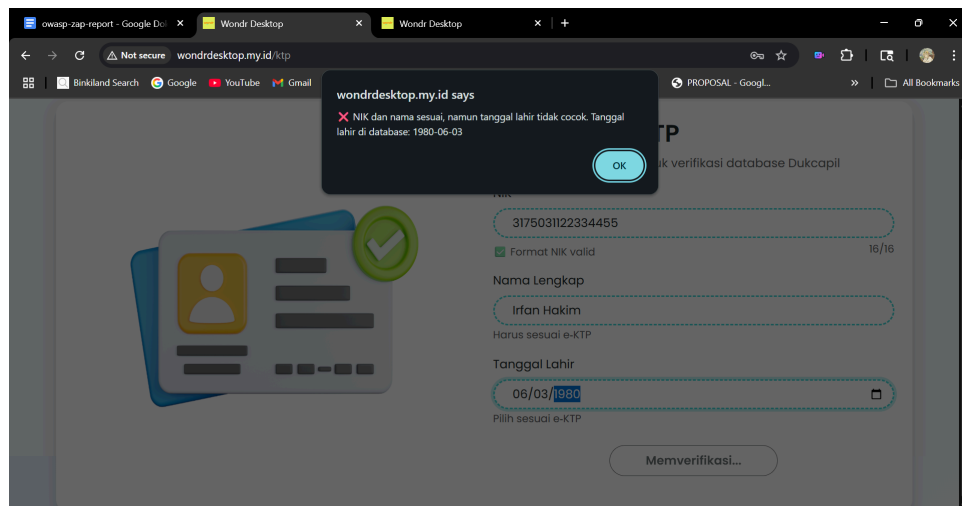
A07:2021 - Identification and Authentication Failures

Proof of Concept

Percobaan pada browser Firefox dengan menggunakan Manual explore dari OWASP Zap:



Percobaan pada browser Chrome



3.1.2. Findings: Expose Version Control System Files

Risk Rating

Risk Severity: HIGH

Risk Score

Likelihood Risk Score	Impact Risk Score
7.25	5.5

Calculated:

<https://owasp-risk-rating.com/?v=6699987483134756>

Tools

- OWASP Zap
- Browser (Chrome)

Description

Web application mengekspos direktori dan file yang terkait dengan *version control system* (VCS). Direktori dapat berisi salinan *source code* aplikasi, riwayat perubahan, informasi konfigurasi internal, maupun informasi penting lainnya yang tidak sengaja *ter-commit*.

Impact

- *Source code* aplikasi dapat terunduh oleh *attacker*
- Informasi sensitif dapat bocor dan terjadi akses tidak sah
- Identifikasi kerentanan lebih lanjut oleh *attacker*

Recommendation

- Menerapkan blokir akses kepada dotfiles atau VCS directories
- Melakukan proses deployment tanpa menyertakan direktori VCS dalam lingkungan produksi yang dapat diakses publik
- Memastikan file sensitif tidak *ter-commit* ke repositori VCS

Involved Team

- DevOps
- Back-End Developer
- Project Manager

References

- https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- https://www.google.com/search?q=https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/02-Configuration_and_Deployment_Management_Testing/03-Information_Disclosure

OWASP Top 10 Category

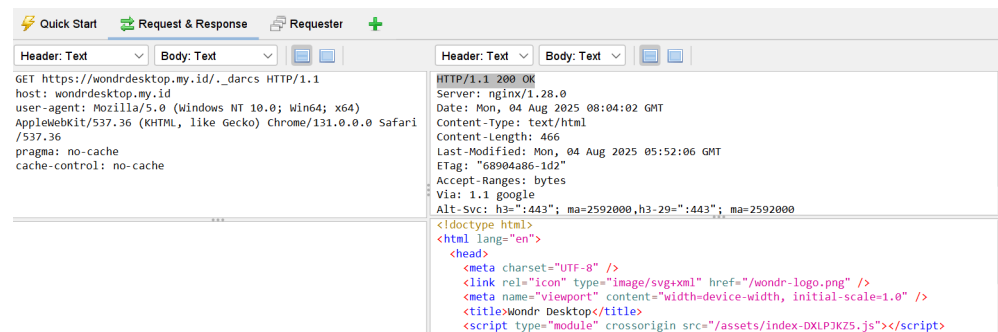
A05:2021 – Security Misconfiguration

Proof of Concept

Penggunaan tools OWASP Zap digunakan untuk melakukan *scanning* pada Hidden File yang ditemukan dan terlihat pada response yang diperoleh dengan status 200 OK. Terdapat file `._darcs`, `._bzzr`, `._hg`, dan BitKeeper

Serta, proses request dan response dari setiap file:

File `._darcs`

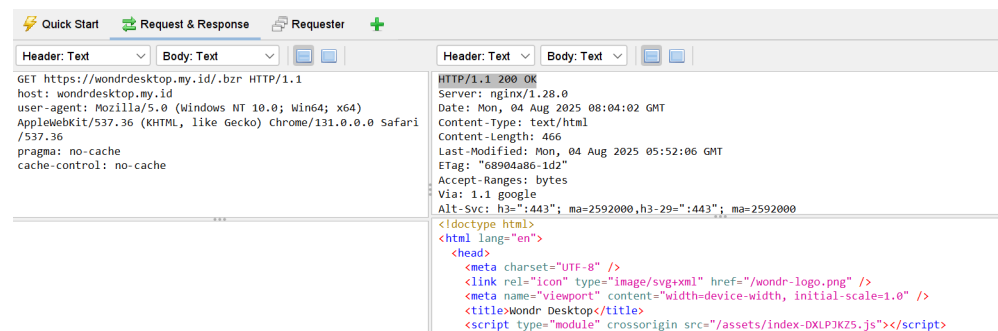


The screenshot shows the OWASP ZAP interface with the 'Request & Response' tab selected. The request is a GET to `https://wondrdesktop.my.id/._darcs` with a status of 200 OK. The response is an HTML document with the following headers and body:

```
HTTP/1.1 200 OK
Server: nginx/1.28.0
Date: Mon, 04 Aug 2025 08:04:02 GMT
Content-Type: text/html
Content-Length: 466
Last-Modified: Mon, 04 Aug 2025 05:52:06 GMT
Etag: "68904a86-1d2"
Accept-Ranges: bytes
Via: 1.1 google
Alt-Svc: h3=":443"; ma=2592000, h3-29=":443"; ma=2592000

<!doctype html>
<html lang="en">
<head>
<meta charset="UTF-8" />
<link rel="icon" type="image/svg+xml" href="/wondr-logo.png" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<title>Wondr Desktop</title>
<script type="module" crossorigin src="/assets/index-DXLPJKZ5.js"></script>
```

File `._bzzr`

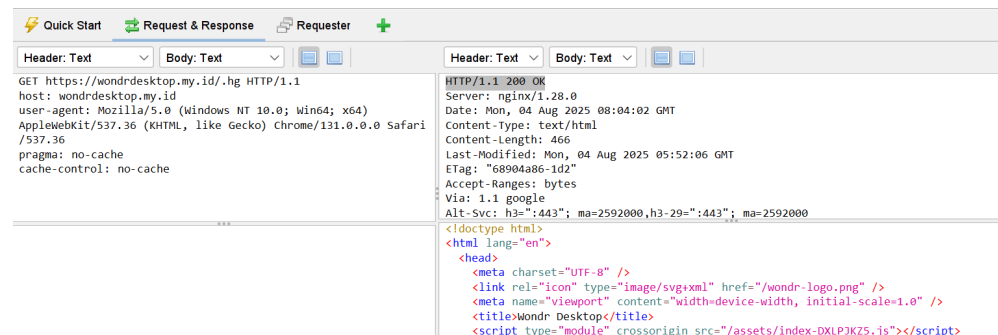


The screenshot shows the OWASP ZAP interface with the 'Request & Response' tab selected. The request is a GET to `https://wondrdesktop.my.id/._bzzr` with a status of 200 OK. The response is an HTML document with the following headers and body:

```
HTTP/1.1 200 OK
Server: nginx/1.28.0
Date: Mon, 04 Aug 2025 08:04:02 GMT
Content-Type: text/html
Content-Length: 466
Last-Modified: Mon, 04 Aug 2025 05:52:06 GMT
Etag: "68904a86-1d2"
Accept-Ranges: bytes
Via: 1.1 google
Alt-Svc: h3=":443"; ma=2592000, h3-29=":443"; ma=2592000

<!doctype html>
<html lang="en">
<head>
<meta charset="UTF-8" />
<link rel="icon" type="image/svg+xml" href="/wondr-logo.png" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<title>Wondr Desktop</title>
<script type="module" crossorigin src="/assets/index-DXLPJKZ5.js"></script>
```

File `._hg`

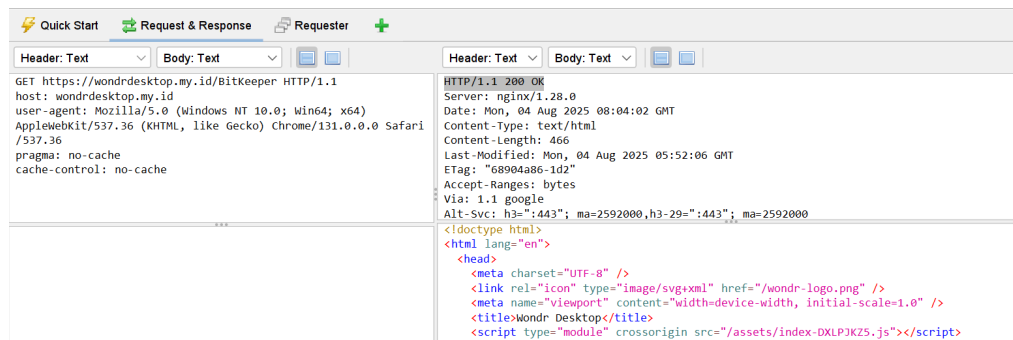


The screenshot shows the OWASP ZAP interface with the 'Request & Response' tab selected. The request is a GET to `https://wondrdesktop.my.id/._hg` with a status of 200 OK. The response is an HTML document with the following headers and body:

```
HTTP/1.1 200 OK
Server: nginx/1.28.0
Date: Mon, 04 Aug 2025 08:04:02 GMT
Content-Type: text/html
Content-Length: 466
Last-Modified: Mon, 04 Aug 2025 05:52:06 GMT
Etag: "68904a86-1d2"
Accept-Ranges: bytes
Via: 1.1 google
Alt-Svc: h3=":443"; ma=2592000, h3-29=":443"; ma=2592000

<!doctype html>
<html lang="en">
<head>
<meta charset="UTF-8" />
<link rel="icon" type="image/svg+xml" href="/wondr-logo.png" />
<meta name="viewport" content="width=device-width, initial-scale=1.0" />
<title>Wondr Desktop</title>
<script type="module" crossorigin src="/assets/index-DXLPJKZ5.js"></script>
```

File BitKeeper



3.1.3. Findings: Expose version Information Response

Risk Rating

Risk Severity: LOW

Risk Score

Likelihood Risk Score	Impact Risk Score
5.25	1.5

Calculated:

<https://owasp-risk-rating.com/?v=9199716011111221>

Tools

- OWASP Zap
- Browser (Chrome)

Description

Web application ini mengekspos informasi mengenai versi *server web* melalui *field header response*.

Impact

- Identifikasi kerentanan lebih lanjut oleh *attacker*
- Penargetan yang lebih akurat oleh *attacker*

Recommendation

- Sembunyikan versi *server web*
- Hapus header “server”
- Melakukan penerapan pada semua web server

Involved Team

- DevOps
- Back-End Development
- Front-End Development
- Project Manager

References

- https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
- https://www.google.com/search?q=https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/02-Configuration_and_Deployment_Management_Testing/03-Information_Disclosure

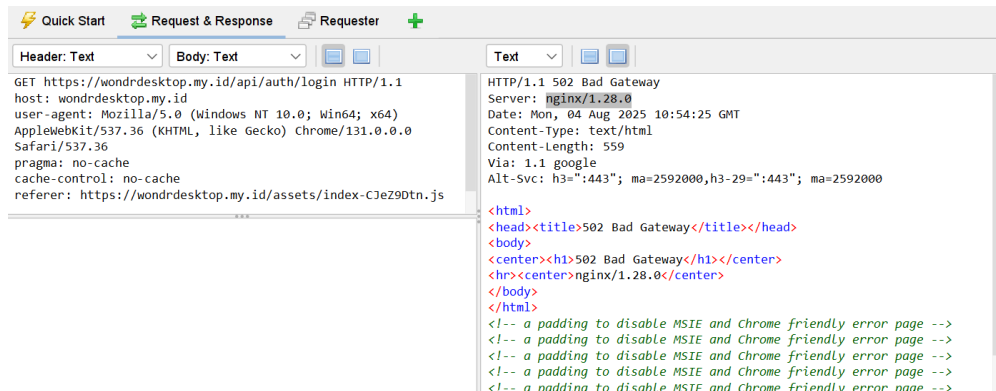
OWASP Top 10 Category

A05:2021 – Security Misconfiguration

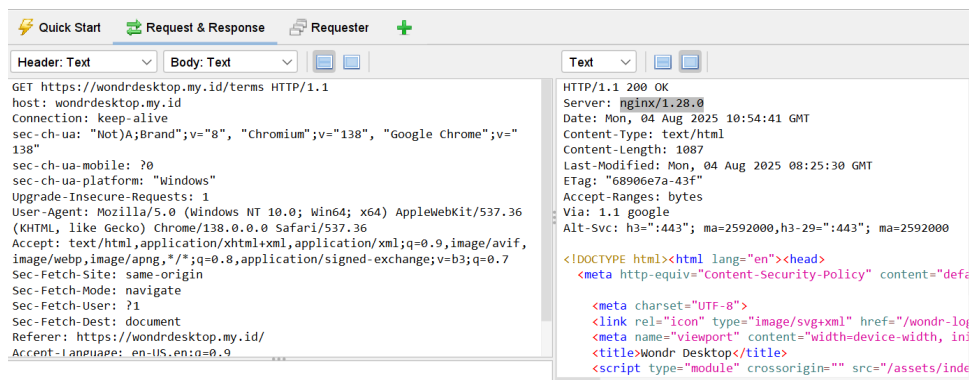
Proof of Concept

Penggunaan tools OWASP Zap digunakan untuk melakukan *scanning* dan memperoleh response sehingga ditemukan version server pada header.

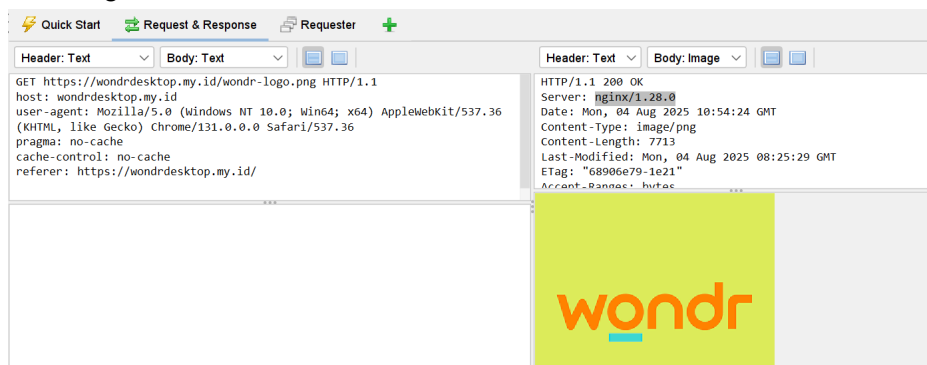
Pada halaman login



Pada halaman terms



Pada logo wondr



3.1.4. Findings: Missing Content Security Policy (CSP) Header

Risk Rating

Risk Severity: MEDIUM

Risk Score

Likelihood Risk Score	Impact Risk Score
5.25	5.25

Calculated:

<https://owasp-risk-rating.com/?v=3959736066254566>

Tools

- OWASP Zap
- Browser (Chrome)

Description

Sistem tidak mengimplementasikan Content-Security-Policy (CSP) pada halaman login (Get Login) dan endpoint *authentication* (Post Login). *Header* CSP berfungsi sebagai lapisan pertahanan di sisi browser untuk mencegah serangan *injection*.

Tanpa CSP, browser akan dapat mengeksekusi seluruh script dan dari berbagai sumber, tanpa membatasinya.

Impact

- Pencurian *credential*, *session*, ataupun *token authentication*
- Serangan *injection* oleh *attacker*
- Penerapan keylogging oleh *attacker*

Recommendation

- Melakukan implementasi header CSP
- Menerapkan kebijakan ketat pada halaman terkait

Involved Team

- DevOps
- Back-End Development
- Front-End Development
- Project Manager

References

- https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
- <https://www.google.com/search?q=https://web.dev/content-security-policy/>

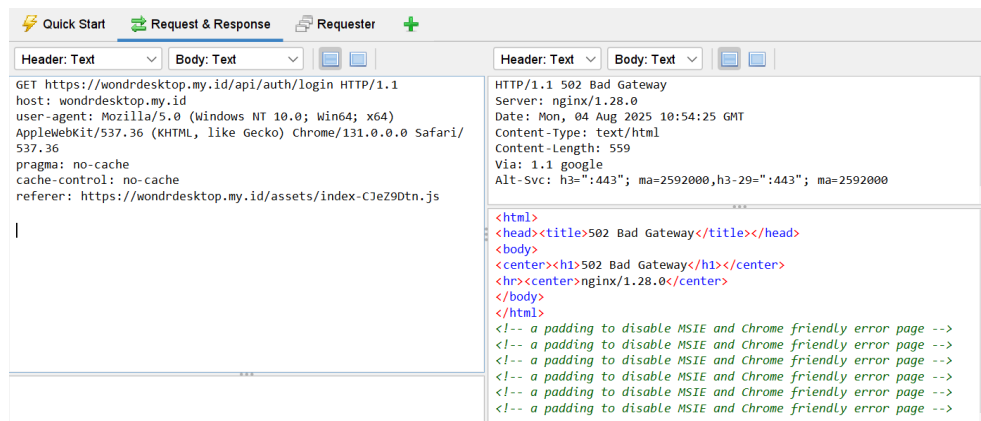
OWASP Top 10 Category

A05:2021 – Security Misconfiguration

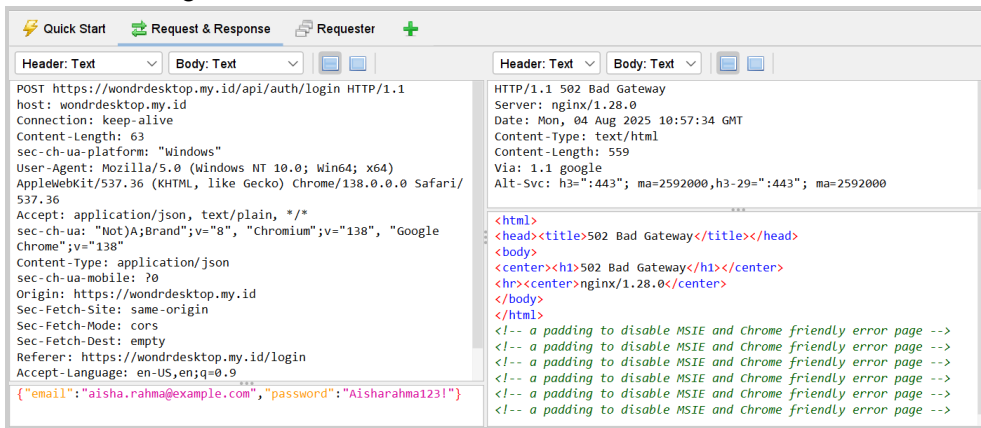
Proof of Concept

Pada penggunaan tools OWASP Zap terlihat response pada Get Login dan Post Login tidak terdapat Content-Security-Policy sehingga tidak adanya penerapan Content Security Policy.

Pada Get Login



Pada Post Login



3.1.5. Findings: Modern Web Application

Risk Rating

Risk Severity: INFORMATIONAL

Risk Score

Likelihood Risk Score	Impact Risk Score
2.875	1.5

Calculated:

<https://owasp-risk-rating.com/?v=2333336042232211>

Tools

- OWASP Zap
- Browser (Chrome)

Description

Web application ini menggunakan arsitektur modern. Hal tersebut terlihat pada script yang terbentuk di response halaman login dan terms.

Impact

- Identifikasi kerentanan lebih lanjut oleh *attacker*

Recommendation

Hal ini menjadi informatical alert sehingga tidak diperlukan perubahan

Involved Team

-

References

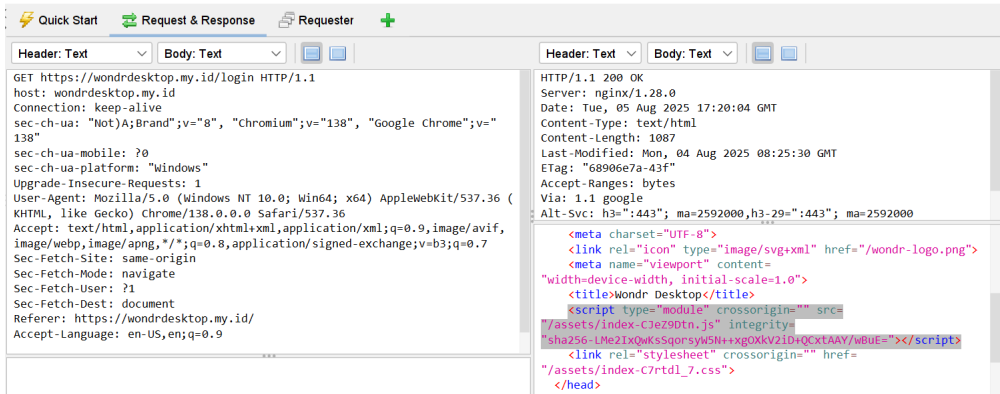
OWASP Top 10 Category

-

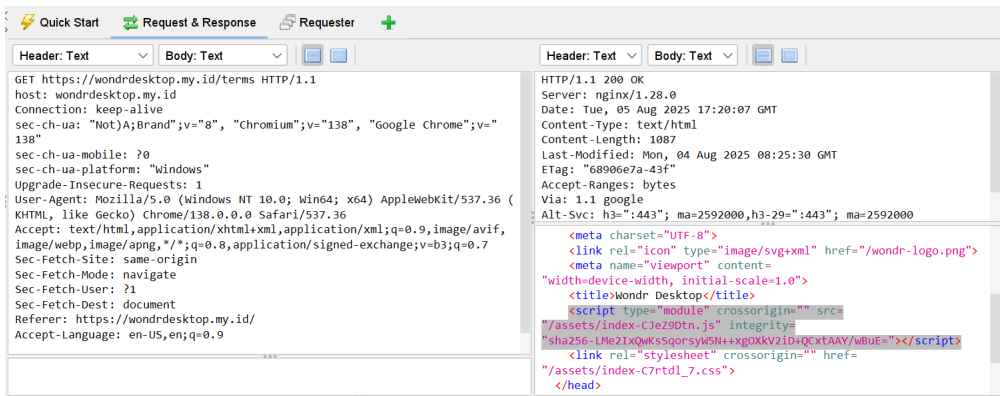
Proof of Concept

Penggunaan tools OWASP Zap membantu melakukan scanning pada halaman yang menunjukkan modern web application.

Pada halaman login



Pada halaman terms



3.1.6. Findings: Missing Anti-Clickjacking

Risk Rating

Risk Severity: MEDIUM

Risk Score

Likelihood Risk Score	Impact Risk Score
5.125	3

Calculated:

<https://owasp-risk-rating.com/?v=5549546324192613>

Tools

- OWASP Zap
- Browser (Chrome)

Description

Web application tidak menyertakan header anti-clickjacking, seperti X-Frame-Options atau Content-Security-Policy: frame-ancestors. Tanpa penggunaan ini, halaman *web* dapat dimuat pada situs berbahaya.

Impact

- Users akan tertipu ketika menekan tombol atau tautan tersembunyi yang telah diletakkan oleh *attacker* sehingga dapat terjadi kebocoran informasi sensitif dan unauthorized access

Recommendation

- Melakukan penambahan pada Content-Security-Policy: frame-ancestors 'self'
- Menambahkan X-Frame-Options: Deny

Involved Team

- Back-End Development
- Frontend-End Development
- Project Manager

References

- https://cheatsheetseries.owasp.org/cheatsheets/Clickjacking_Defense_Cheat_Sheet.html
- https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/07-Client_Side_Testing/03-Testing_for_Clickjacking.html

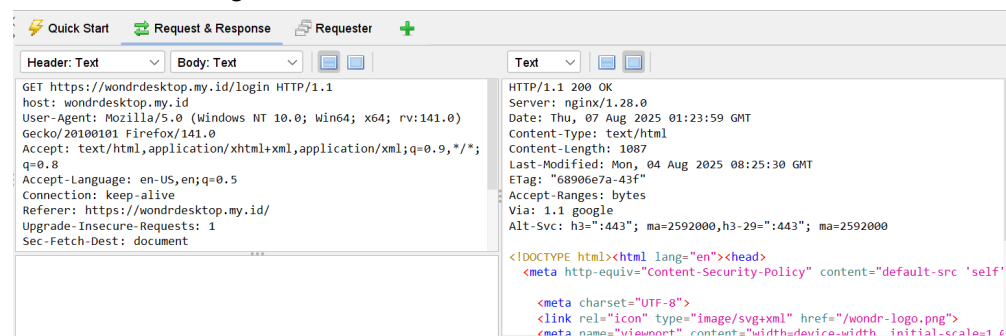
OWASP Top 10 Category

A05:2021 – Security Misconfiguration

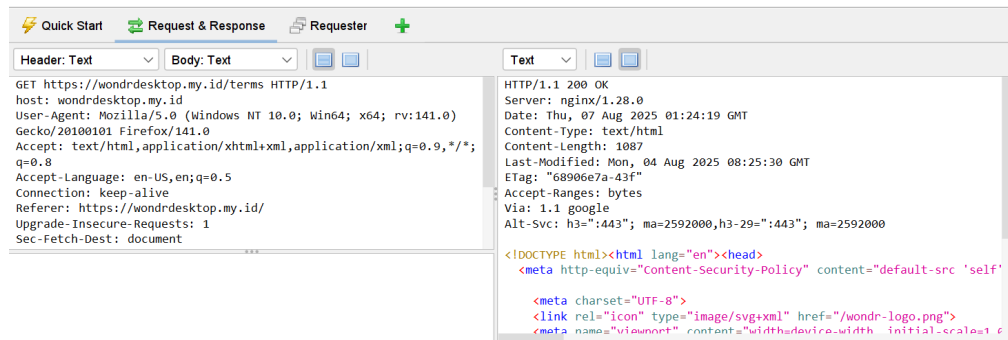
Proof of Concept

Response yang diperoleh tidak menunjukkan telah diterapkannya Anti-Clickjacking.

Pada halaman login



Pada halaman terms



3.1.7. Testing Vulnerability: SQL Injection

Tools

- Burp Suite
- Browser (Chrome)

Description

SQL Injection pada *web application* menunjukkan tidak adanya serangan yang dilakukan dapat menembus *web application*.

Impact

-

Recommendation

-

Involved Team

-

References

-

OWASP Top 10 Category

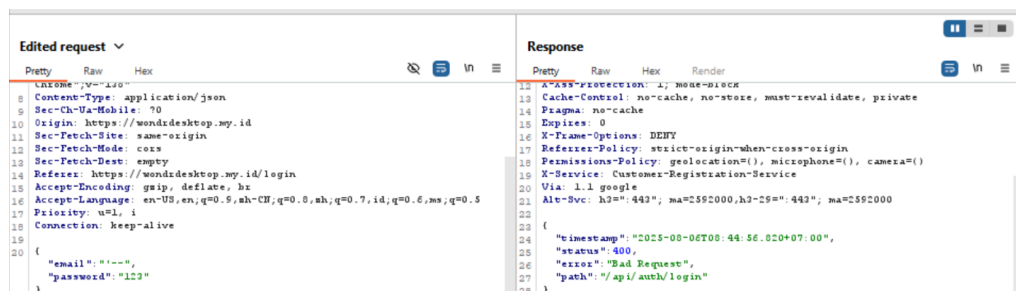
A03:2021 - Injection

Proof of Concept

Penggunaan burp suite dengan melakukan intercept dilakukan dengan berbagai percobaan untuk dapat melihat celah *SQL injection*.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start resp
3	https://wondrdesktop.my.id	POST	/api/auth/login		✓	400	946	JSON				✓	34.49.249.12		08:18:57.6 A.	8080	329
4	https://wondrdesktop.my.id	POST	/api/auth/login		✓	400	946	JSON				✓	34.49.249.12		08:45:28.6 A.	8080	268
5	https://wondrdesktop.my.id	POST	/api/auth/login		✓	400	946	JSON				✓	34.49.249.12		10:16:58.6 A.	8080	29
6	https://wondrdesktop.my.id	POST	/api/auth/login		✓	401	886	JSON				✓	34.49.249.12		10:17:42.6 A.	8080	125
7	https://wondrdesktop.my.id	POST	/api/auth/login		✓	401	886	JSON				✓	34.49.249.12		10:18:02.6 A.	8080	31
8	https://wondrdesktop.my.id	POST	/api/auth/login		✓	401	904	JSON				✓	34.49.249.12		10:18:30.6 A.	8080	
11	https://wondrdesktop.my.id	POST	/api/auth/login		✓	400	946	JSON				✓	34.49.249.12		10:24:19.6 A.	8080	524
12	https://wondrdesktop.my.id	POST	/api/auth/login		✓	400	946	JSON				✓	34.49.249.12		10:24:39.6 A.	8080	47
13	https://wondrdesktop.my.id	POST	/api/auth/login		✓	400	946	JSON				✓	34.49.249.12		10:40:08.6 A.	8080	30
14	https://wondrdesktop.my.id	POST	/api/auth/login		✓	401	886	JSON				✓	34.49.249.12		10:42:20.6 A.	8080	66
15	https://wondrdesktop.my.id	POST	/api/auth/login		✓	401	886	JSON				✓	34.49.249.12		10:50:46.6 A.	8080	62
16	https://wondrdesktop.my.id	POST	/api/auth/login		✓	400	946	JSON				✓	34.49.249.12		10:55:05.6 A.	8080	31
17	https://wondrdesktop.my.id	POST	/api/auth/login		✓	401	886	JSON				✓	34.49.249.12		10:55:30.6 A.	8080	63
18	https://wondrdesktop.my.id	POST	/api/auth/login		✓	400	946	JSON				✓	34.49.249.12		10:56:33.6 A.	8080	31
19	https://wondrdesktop.my.id	POST	/api/auth/login		✓	400	946	JSON				✓	34.49.249.12		10:57:21.6 A.	8080	31
20	https://wondrdesktop.my.id	POST	/api/auth/login		✓	401	886	JSON				✓	34.49.249.12		11:23:34.6 A.	8080	346
21	https://wondrdesktop.my.id	POST	/api/auth/login		✓	401	904	JSON				✓	34.49.249.12		11:24:49.6 A.	8080	565
22	https://wondrdesktop.my.id	POST	/api/auth/login		✓	401	886	JSON				✓	34.49.249.12		11:26:11.6 A.	8080	31
23	https://wondrdesktop.my.id	POST	/api/auth/login		✓	400	946	JSON				✓	34.49.249.12		11:29:37.6 A.	8080	51

Usaha *injection* pada kolom username dan password



Edited request

PrettyRawHex

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

Sec-Ch-Ua: "Not A;Brand",v="0", "Chromium",v="120", "Google Chrome",v="120"

Content-Type: application/json

Sec-Ch-Ua-Mobile: ?0

Origin: https://wonddesktop.my.id

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: cors

Sec-Fetch-Dest: empty

Referer: https://wonddesktop.my.id/login

Accept-Encoding: gzip, deflate, br

Accept-Language: en-US,en;q=0.5,sh-CN;q=0.0,sh;q=0.7,id;q=0.6,ms;q=0.5

Priority: u=1, i

{

"email": "admin' --",

"password": "123"

}

Response

PrettyRawHexRender

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

HTTP/2 400 Bad Request

Server: nginx/1.20.0

Date: Wed, 06 Aug 2025 02:16:05 GMT

Content-Type: application/json

Vary: Origin

Vary: Access-Control-Request-Method

Vary: Access-Control-Request-Headers

Access-Control-Allow-Origin: https://wonddesktop.my.id

Access-Control-Expose-Headers: Access-Control-Allow-Origin, Access-Control-Allow-Credentials, Authorization

Access-Control-Allow-Credentials: true

X-Content-Type-Options: nosniff

X-Xss-Protection: 1; mode=block

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

X-Frame-Options: DENY

Edited request

PrettyRawHex

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

Sec-Ch-Ua: "Not A;Brand",v="0", "Chromium",v="120", "Google Chrome",v="120"

Content-Type: application/json

Sec-Ch-Ua-Mobile: ?0

Origin: https://wonddesktop.my.id

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: cors

Sec-Fetch-Dest: empty

Referer: https://wonddesktop.my.id/login

Accept-Encoding: gzip, deflate, br

Accept-Language: en-US,en;q=0.5,sh-CN;q=0.0,sh;q=0.7,id;q=0.6,ms;q=0.5

Priority: u=1, i

{

"email": "ORL1--",

"password": "123"

}

Response

PrettyRawHexRender

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

X-Xss-Protection: 1; mode=block

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

X-Frame-Options: DENY

Referer-Policy: strict-origin-when-cross-origin

Permissions-Policy: geolocation(), microphone(), camera=()

X-Service: Customer-Registration-Service

Via: 1.1 google

Alt-Svc: h3="443"; ma=2592000,h3-29="443"; ma=2592000

{

"timestamp": "2025-08-06T10:17:21.052+07:00",

"status": 400,

"error": "Bad Request",

"path": "/api/auth/login"

}

Edited request

PrettyRawHex

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

Accept: application/json, text/plain, *

Sec-Ch-Ua: "Not A;Brand",v="0", "Chromium",v="120", "Google Chrome",v="120"

Content-Type: application/json

Sec-Ch-Ua-Mobile: ?0

Origin: https://wonddesktop.my.id

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: cors

Sec-Fetch-Dest: empty

Referer: https://wonddesktop.my.id/login

Accept-Encoding: gzip, deflate, br

Accept-Language: en-US,en;q=0.5,sh-CN;q=0.0,sh;q=0.7,id;q=0.6,ms;q=0.5

Priority: u=1, i

{

"email": "admin'||'1'='1--@example.com",

"password": "123"

}

Response

PrettyRawHexRender

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

Access-Control-Allow-Credentials: true

X-Content-Type-Options: nosniff

X-Xss-Protection: 1; mode=block

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

X-Frame-Options: DENY

Referer-Policy: strict-origin-when-cross-origin

Permissions-Policy: geolocation(), microphone(), camera=()

X-Service: Customer-Registration-Service

Via: 1.1 google

Alt-Svc: h3="443"; ma=2592000,h3-29="443"; ma=2592000

{

"timestamp": "2025-08-06T10:17:21.052+07:00",

"status": 400,

"error": "Bad Request",

"path": "/api/auth/login"

}

Edited request

PrettyRawHex

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

Accept: application/json, text/plain, *

Sec-Ch-Ua: "Not A;Brand",v="0", "Chromium",v="120", "Google Chrome",v="120"

Content-Type: application/json

Sec-Ch-Ua-Mobile: ?0

Origin: https://wonddesktop.my.id

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: cors

Sec-Fetch-Dest: empty

Referer: https://wonddesktop.my.id/login

Accept-Encoding: gzip, deflate, br

Accept-Language: en-US,en;q=0.5,sh-CN;q=0.0,sh;q=0.7,id;q=0.6,ms;q=0.5

Priority: u=1, i

{

"email": "admin'AND(SELECT/**/pg_sleep(5))--@gmail.com",

"password": "123"

}

Response

PrettyRawHexRender

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

X-Xss-Protection: 1; mode=block

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

X-Frame-Options: DENY

Referer-Policy: strict-origin-when-cross-origin

Permissions-Policy: geolocation(), microphone(), camera=()

X-Service: Customer-Registration-Service

Via: 1.1 google

Alt-Svc: h3="443"; ma=2592000,h3-29="443"; ma=2592000

{

"timestamp": "2025-08-06T10:56:45.760+07:00",

"status": 400,

"error": "Bad Request",

"path": "/api/auth/login"

}

Edited request

PrettyRawHex

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

Accept: application/json, text/plain, *

Sec-Ch-Ua: "Not A;Brand",v="0", "Chromium",v="120", "Google Chrome",v="120"

Content-Type: application/json

Sec-Ch-Ua-Mobile: ?0

Origin: https://wonddesktop.my.id

Sec-Fetch-Site: same-origin

Sec-Fetch-Mode: cors

Sec-Fetch-Dest: empty

Referer: https://wonddesktop.my.id/login

Accept-Encoding: gzip, deflate, br

Accept-Language: en-US,en;q=0.5,sh-CN;q=0.0,sh;q=0.7,id;q=0.6,ms;q=0.5

Priority: u=1, i

{

"email": "john.doe@example.com",

"password": "%UNION/**/SELECT/**/ 'admin', 'hashedpass'--"

}

Response

PrettyRawHexRender

1

2

3

4

5

6

7

8

9

10

11

12

13

14

15

16

17

18

19

20

21

22

23

24

25

26

27

28

Access-Control-Allow-Credentials: true

X-Content-Type-Options: nosniff

X-Xss-Protection: 1; mode=block

Cache-Control: no-cache, no-store, must-revalidate, private

Pragma: no-cache

Expires: 0

X-Frame-Options: DENY

Referer-Policy: strict-origin-when-cross-origin

Permissions-Policy: geolocation(), microphone(), camera=()

X-Service: Customer-Registration-Service

Via: 1.1 google

Alt-Svc: h3="443"; ma=2592000,h3-29="443"; ma=2592000

{

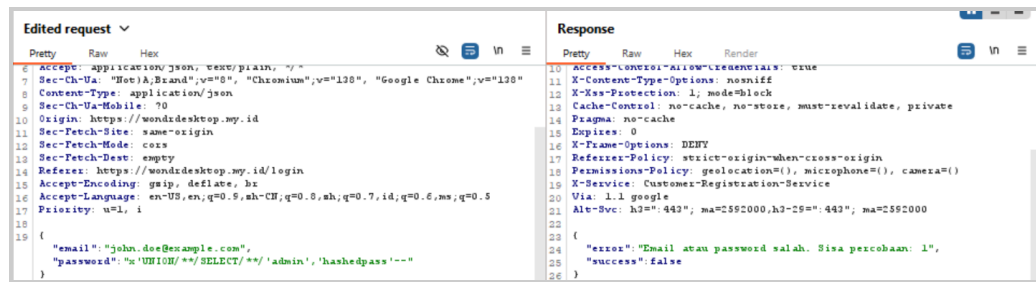
"timestamp": "2025-08-06T10:56:45.760+07:00",

"status": 400,

"error": "Email atau password salah. Sisa percobaan: 1",

"success": false

}



4. BUSINESS RISK

Temuan kerentanan yang teridentifikasi dalam laporan ini, khususnya pada tingkat Kritis dan Tinggi, menimbulkan risiko bisnis yang signifikan dan harus segera ditangani. Kerentanan enumerasi pada halaman verifikasi KTP secara langsung mengancam kerahasiaan data pribadi customers (NIK, nama lengkap, dan tanggal lahir), yang dapat digunakan untuk serangan lanjutan seperti *brute-force* atau pencurian identitas. Paparan ini dapat merusak kepercayaan customers, menyebabkan kerugian reputasi yang parah, dan berpotensi menimbulkan sanksi hukum dari regulator data.

Eksposur file sistem kontrol versi (.hg, .bzd, dll.) merupakan risiko pencurian kekayaan intelektual, di mana seluruh kode sumber aplikasi dapat diakses oleh *attacker*. Pengetahuan tentang kode sumber ini tidak hanya membocorkan logika bisnis, tetapi juga memfasilitasi *attacker* untuk menemukan dan mengeksploitasi celah keamanan lain yang lebih dalam. Kegagalan dalam mengelola risiko ini dapat mengakibatkan kerugian finansial yang besar dan mengganggu operasional bisnis secara keseluruhan.

5. GENERAL RECOMMENDATIONS

Secara umum, untuk meningkatkan postur keamanan aplikasi web, direkomendasikan untuk menerapkan pendekatan keamanan yang lebih proaktif dan berlapis.

Pertama, perkuat validasi di sisi *server* dan terapkan praktik pengkodean yang aman untuk mengatasi kerentanan injeksi dan enumerasi. Pastikan pesan kesalahan yang ditampilkan bersifat generik dan seragam untuk mencegah pengungkapan informasi sensitif.

Kedua, perbaiki konfigurasi *server* untuk mengatasi *security misconfiguration*. Ini termasuk menghapus *header* respons yang membocorkan versi *server* (misalnya, Nginx) dan memastikan direktori sensitif (seperti file VCS) tidak dapat diakses publik.

Ketiga, terapkan *header* keamanan penting di seluruh aplikasi, terutama di halaman-halaman yang sensitif. Ini mencakup implementasi Content-Security-Policy (CSP) yang ketat untuk mencegah serangan injeksi dan **Cross-Site Scripting (XSS)**, serta X-Frame-Options atau frame-ancestors untuk mencegah serangan

clickjacking. **Terakhir**, adopsi siklus pengembangan perangkat lunak yang aman (SDLC) dengan memasukkan pengujian keamanan secara rutin.

6. CONCLUSION

Laporan ini telah berhasil mengidentifikasi dan mendokumentasikan serangkaian kerentanan pada aplikasi web `wondrdesktop.my.id` yang memiliki dampak signifikan pada keamanan. Temuan-temuan ini, yang mencakup satu kerentanan **Kritis**, satu **Tinggi**, dan beberapa **Sedang** dan **Rendah**, menunjukkan bahwa aplikasi tersebut memiliki beberapa celah yang dapat dieksploitasi oleh *attacker*.

Risiko utama yang teridentifikasi adalah potensi kebocoran data sensitif customers, pencurian *source code*, dan serangan *injection* yang dapat mengarah pada penyerangan akun. Meskipun demikian, kerentanan yang ditemukan dapat diperbaiki dengan mengimplementasikan rekomendasi yang telah diberikan, seperti perbaikan pada validasi *input*, pengerasan konfigurasi *server*, dan penerapan *header* keamanan yang relevan. Dengan mengambil tindakan yang cepat dan tepat untuk mengatasi masalah ini, keamanan aplikasi dapat ditingkatkan secara signifikan dan risiko terhadap bisnis dapat diminimalkan.